Relatório de Análise de Riscos de Segurança

Mapeamento de vulnerabilidades, avaliação quantitativa de impacto x probabilidade, inventário de controles mitigatórios e plano de resposta para a plataforma EstudeMy (Mobile & API).

1. Critério de Avaliação e Metodologia de Riscos

A metodologia adota a matriz quantitativa padrão (ISO/IEC 27005 e OWASP), mensurando o nível de risco inerente através do produto da severidade do impacto pela frequência estimada da probabilidade.

Cálculo do Risco Inerente: `Risco = Impacto (I) × Probabilidade (P)`

1 a 10: Baixo	11 a 30: Médio	31 a 64: Alto	65 a 100: Crítico

Escala de Impactos (Magnitude de Severidade)

Magnitude	Descrição do Impacto Operacional / Negócio	I
Muito baixo	Degradação causando impactos mínimos nos objetivos, prazos e metas.	1
Baixo	Degradação com impactos pequenos e recuperáveis nos objetivos.	2
Médio	Interrupção causando impactos significativos, porém reversíveis.	5
Alto	Interrupção de reversão muito difícil nos objetivos e na reputação.	8
Muito alto	Paralisação geral causando impactos irreversíveis ou catastróficos.	10

Escala de Probabilidades (Frequência de Ocorrência)

Magnitude	Descrição da Possibilidade de Ocorrência	P
Muito baixa	Evento improvável; sem registros ou indícios de exploração ativa.	1
Baixa	Evento raro; pode ocorrer de forma inesperada e esporádica.	2
Média	Evento possível; elementos indicam moderadamente a ocorrência.	5
Alta	Evento provável; informações indicam de forma consistente o risco.	8
Muito alta	Evento quase certo; indícios claros e frequentes de exploração.	10

📋 Diretrizes de Tratamento de Riscos

Os controles são classificados em três status operacionais: **Mitigado** (controles técnicos implementados e validados em ambiente de produção), **Em Mitigação** (medidas em fase de implementação técnica ou rollout gradativo) e **Pendente** (vulnerabilidades sem controles ativos, exigindo atuação prioritária da equipe de desenvolvimento).

2. Matriz Consolidada de Riscos e Vulnerabilidades

Mapeamento dos 11 pontos auditados, contendo ações mitigatórias, equipe responsável e cálculo do Risco Inerente.

VULNERABILIDADE	TRATAMENTO	AÇÃO MITIGATÓRIA	RESP.	CÓD.	DESCRIÇÃO DO RISCO-CHAVE	I	P	RISCO	NÍVEL
SQL Injection	Mitigado	ORM, Prepared Statements e tipagem estrita via DTO em 100% das rotas.	Dev	RC01	Injeção SQL permitindo extração, alteração ou deleção de dados cadastrais/progresso.	8	1	8	Baixo
Cross-Site Scripting (XSS)	Em Mitigação	Sanitização de dados de entrada, encoding nas saídas e política CSP ativa.	Dev	RC02	Scripts maliciosos em campos livres executando no cliente para roubo de sessão.	5	5	25	Médio
Session Hijacking	Mitigado	JWT de curta duração + Refresh Tokens com rotação, MFA e expo-secure-store.	Dev	RC03	Interceptação de token JWT concedendo controle total sobre a conta sem a senha.	8	2	16	Médio
Brute Force & Credential Stuffing	Em Mitigação	Rate Limiting progressivo por IP/conta, CAPTCHA adaptativo e hash Bcrypt/Argon2.	Dev / Infra	RC04	Testes em massa de senhas comuns/vazadas na rota de login, causando invasões e sobrecarga.	5	8	40	Alto
Phishing e Eng. Social	Pendente	Treinamento corporativo, SPF/DKIM/DMARC no domínio e canal de denúncia.	SecOps / RH	RC05	Indução de alunos, professores ou admins a entregar credenciais por e-mails clonados.	8	5	40	Alto
IDOR (Insecure Direct Object Ref.)	Pendente	Validação de ownership (autorização a nível de objeto) no backend e adoção de UUIDs.	Dev	RC06	Acesso ou edição indevida de dados de terceiros alterando IDs na URL sem checagem de posse.	8	8	64	Alto
Privilege Escalation	Pendente	RBAC rigoroso no backend, validação por middleware e bloqueio de mass assignment.	Dev	RC07	Aluno alterando perfil para obter privilégios de Professor ou Administrador do sistema.	10	2	20	Médio
DDoS (Denial of Service)	Em Mitigação	WAF com mitigação anti-DDoS (Cloudflare), rate limiting e autoscaling de containers.	Infra	RC08	Inundação de tráfego tornando os serviços indisponíveis em provas e horários de pico.	5	5	25	Médio
Race Condition	Em Mitigação	Transações ACID com lock pessimista (FOR UPDATE) e restrições de unicidade (UNIQUE).	Dev	RC09	Requisições paralelas simultâneas duplicando moedas, vidas ou recompensas de gamificação.	2	5	10	Baixo
Data Exposure	Pendente	TLS 1.3, filtragem de DTOs nas respostas e supressão de stack traces em produção.	Dev / SecOps	RC10	Vazamento acidental de dados pessoais (PII) em logs de erro ou payloads da API (LGPD).	8	5	40	Alto
Directory Traversal	Pendente	Sanitização estrita com path.basename() e armazenamento em bucket seguro na nuvem (S3).	Dev	RC11	Manipulação de caminhos (../../) para leitura não autorizada de arquivos .env ou código-fonte.	10	2	20	Médio

⚖️ Conformidade e Privacidade (LGPD)

Destaca-se especial urgência nos itens **RC06 (IDOR)** e **RC10 (Data Exposure)**, cujos vetores afetam diretamente dados de menores de idade e registros educacionais protegidos pela Lei Geral de Proteção de Dados (Lei 13.709/2018), expondo a organização a riscos regulatórios e sanções pecuniárias.

3. Detalhamento e Justificativas Técnicas (Itens 1 a 11)

Fundamentação técnica das notas atribuídas e catálogo de ações corretivas recomendadas.

1. SQL Injection (RC01) — R: 8 (Baixo)

Justificativa: Impacto Alto (8) por comprometer o banco de dados; Probabilidade Muito Baixa (1) pelo uso consolidado de ORM.

Ação Prática: Proibir queries manuais concatenadas; manter linter ativo para barrar SQL puro no CI/CD.

2. Cross-Site Scripting — XSS (RC02) — R: 25 (Médio)

Justificativa: Impacto Médio (5) com roubo de sessão; Probabilidade Média (5) comum em campos de texto livre (chat/bio).

Ação Prática: Sanitizar com DOMPurify; aplicar escape automático e reforçar cabeçalhos CSP bloqueando inline scripts.

3. Session Hijacking (RC03) — R: 16 (Médio)

Justificativa: Impacto Alto (8) por personificação total; Probabilidade Baixa (2) devido a TLS e expo-secure-store.

Ação Prática: Rotação ativa de Refresh Tokens, blacklist de revogação no logout e MFA para administradores.

4. Brute Force & Stuffing (RC04) — R: 40 (Alto)

Justificativa: Impacto Médio (5); Probabilidade Alta (8), pois endpoints de login sofrem varredura de bots contínua.

Ação Prática: Rate Limiting estrito (5 erros/15min), CAPTCHA progressivo e algoritmo Bcrypt/Argon2 com salt.

5. Phishing & Eng. Social (RC05) — R: 40 (Alto)

Justificativa: Impacto Alto (8) se atingir administradores; Probabilidade Média (5) explorando erro humano.

Ação Prática: Treinamentos periódicos de conscientização e configuração estrita de SPF, DKIM e DMARC no domínio.

6. IDOR (RC06) — R: 64 (Alto)

Justificativa: Impacto Alto (8) violando a LGPD; Probabilidade Alta (8) em rotas com IDs sequenciais sem checagem de posse.

Ação Prática: Validar se o recurso pertence ao usuário autenticado (`ownerId`) e migrar IDs inteiros para UUID v4.

7. Privilege Escalation (RC07) — R: 20 (Médio)

Justificativa: Impacto Muito Alto (10); Probabilidade Baixa (2) com RBAC centralizado em middlewares de backend.

Ação Prática: Bloquear mass assignment (não aceitar campo `role` no body de cadastro) e validar permissões no token.

8. DDoS (RC08) — R: 25 (Médio)

Justificativa: Impacto Médio (5) com indisponibilidade; Probabilidade Média (5) devido a ferramentas públicas de estresse.

Ação Prática: Borda com Cloudflare WAF, rate limit por IP e configuração de autoscaling horizontal nos servidores.

9. Race Condition (RC09) — R: 10 (Baixo)

Justificativa: Impacto Baixo (2) afetando pontuação gamificada; Probabilidade Média (5) sem travas de concorrência.

Ação Prática: Transações ACID com lock pessimista (`FOR UPDATE`) ou filas redis atômicas para entrega de moedas/XP.

10. Data Exposure (RC10) — R: 40 (Alto)

Justificativa: Impacto Alto (8) sob a LGPD; Probabilidade Média (5) em APIs que serializam entidades cruas do banco.

Ação Prática: Aplicar DTOs para excluir senhas e CPFs do JSON retornado; suprimir stack traces de erro em produção.

11. Directory Traversal (RC11) — R: 20 (Médio)

Justificativa: Impacto Muito Alto (10) por exposição potencial de arquivos de sistema e variáveis `.env`; Probabilidade Baixa (2) com storage em nuvem.

Ação Prática: Sanitizar caminhos recebidos com `path.basename()`, proibir sequências `../` e delegar upload de avatares a buckets S3 gerenciados.

4. Priorização de Tratamento Recomendada (Plano de Resposta)

Classificação cronológica das ações mitigatórias baseada no Nível de Risco Inerente para alocação de equipe.

🔥 RISCO ALTO (Tratar Imediatamente / Sprint Atual)	Faixa de Pontuação: 31 a 64
1º. IDOR (RC06) — Validação de Propriedade de Recursos (Ownership Check)	Score: 64
2º. Data Exposure (RC10) — Prevenção a Vazamento de PII e DTOs Estritos (LGPD)	Score: 40
3º. Brute Force & Stuffing (RC04) — Rate Limiting e Bloqueio de Dicionários	Score: 40
4º. Phishing e Engenharia Social (RC05) — SPF/DKIM/DMARC e Conscientização	Score: 40

⚠️ RISCO MÉDIO (Planejar para Próximos Sprints / Monitorar)	Faixa de Pontuação: 11 a 30
5º. Cross-Site Scripting - XSS (RC02) — Sanitização com DOMPurify e CSP	Score: 25
6º. DDoS (RC08) — Proteção de Borda e WAF (Cloudflare)	Score: 25
7º. Privilege Escalation (RC07) — RBAC no Backend e Proteção Mass Assignment	Score: 20
8º. Directory Traversal (RC11) — Sanitização de Caminhos e Storage em Nuvem	Score: 20
9º. Session Hijacking (RC03) — Rotação de Refresh Tokens e MFA	Score: 16

✅ RISCO BAIXO (Manter Controles Ativos / Backlog de Melhoria)	Faixa de Pontuação: 1 a 10
10º. Race Condition (RC09) — Transações com Lock e Filas Concorrentes	Score: 10
11º. SQL Injection (RC01) — Queries Parametrizadas e ORM em Produção	Score: 8

5. Termo de Homologação e Responsabilidade Técnica

Engenharia de Software	Segurança da Informação	Privacidade e Dados
Tech Lead / Desenvolvimento	SecOps / DevSecOps	Encarregado de Dados (DPO)